

# Plan Ejecutivo a 10/10

Protección de datos · Campaña de marketing · Roadmap de producto

Documento para fundadores e inversionistas. Basado en una auditoría de 14 fases verificada contra el código real del repositorio y el sitio en producción (www.rowiia.com), no contra suposiciones. Cada afirmación técnica lleva su veredicto: verificada, parcial o descartada.

|          |                                                              |
|----------|--------------------------------------------------------------|
| Fecha    | 5 de junio de 2026                                           |
| Producto | Rowi — Social Interaction Algorithm (SIA)                    |
| Stack    | Next.js 16 · Prisma · Postgres (Neon) · Vercel · Six Seconds |
| Go-live  | EQ Day — 6 de junio de 2026 (cohorte controlada)             |
| Autor    | Auditoría técnica verificada                                 |

## 0 · Resumen ejecutivo

Rowi tiene una tesis fuerte y una infraestructura sorprendentemente sólida. La auditoría externa que motivó este trabajo erró en su propio terreno técnico: cerca del 60% de sus hallazgos P0/P1 describían código que ya había sido migrado (home server-side, robots/sitemap, CSRF, webhook). Sin embargo, no detectó el único riesgo verdaderamente caro:

**Hallazgo P0 real (ya resuelto en esta sesión):** 600 MB de datos de benchmark Six Seconds —incluido un CSV «anonymized full unfiltered»— se servían sin autenticación desde **public/**, descargables por cualquiera en [www.rowiia.com](http://www.rowiia.com). Era una fuga de nuestro activo de datos más valioso y un riesgo GDPR.

**Estado tras esta sesión:** la fuga está cerrada. **public/** pasó de 616 MB a 10 MB. Se confirmó que los archivos nunca se commitearon a git (cero blobs >5 MB en todo el historial), por lo que no hay nada publicado que purgar. Los datos viven ahora en almacenamiento privado como «semilla del benchmark».

| Veredicto de lanzamiento          | Recomendación                                                        |
|-----------------------------------|----------------------------------------------------------------------|
| Lanzamiento masivo (100k) mañana  | <b>No.</b> Faltan 2 P0 reales y endurecimiento de auth.              |
| Cohorte controlada EQ Day (6-jun) | <b>Sí,</b> con los P0 cerrados. La arquitectura aguanta una cohorte. |

# 1 · Protección de datos — el plan que nos lleva a 10/10

---

## 1.1 · Lo que ya se hizo en esta sesión

- ✓ **Datasets fuera de public/**. SOH (291 MB + 307 MB), TP Assessments (7.3 MB) y CSVs reales movidos a **data/seed/** (privado). public/: 616 MB → 10 MB.
- ✓ **Historial verificado limpio**. Cero blobs >5 MB en todo el árbol git. Nunca se publicaron. No requiere reescritura de historial ni force-push.
- ✓ **.gitignore blindado**. Regla explícita **/data/seed/** además del \*.csv / \*.xlsx ya existente.
- ✓ **Loader de semilla** (src/lib/benchmark/seedSource.ts): resuelve los datasets desde almacenamiento privado con *fail-closed* — nunca cae a una fuente pública.
- ✓ **Script de carga** (scripts/upload-benchmark-seed.ts) y referencia de import actualizada. TypeScript compila limpio (tsc exit 0, strict).

## 1.2 · Advertencia honesta sobre Vercel Blob

@vercel/blob v2 solo soporta acceso «public». Las URLs son largas e inadivinas, pero técnicamente accesibles si el enlace se filtra. Para un dataset «anonymized full unfiltered» eso **no es privacidad real**. Recomendación para llegar a 10/10:

- **Corto plazo (hoy)**: subir a Blob con pathname secreto, nunca exponer la URL en cliente/logs. Cierra la descarga abierta inmediata.
- **10/10 (semana 1)**: migrar a un bucket privado real — **AWS S3 o Cloudflare R2** con *URLs firmadas* de expiración corta. El loader ya está abstraído para cambiar solo la implementación de lectura.
- **Gobernanza**: registrar quién accede al dataset crudo (ya existe ResearchAccessAudit para el patrón); el seed solo se lee en build/seed, nunca en runtime de usuario.

## 1.3 · Política para que no vuelva a pasar

- **Regla dura**: public/ solo contiene assets estáticos públicos (imágenes, fuentes, manifest). Cero datos de personas, cero CSV/XLSX. Ya está en .gitignore.
- **Pre-commit / CI guard**: añadir un check que falle el build si aparece un \*.csv/\*.xlsx o un archivo >5 MB bajo public/.
- **Optimizar assets restantes**: favicon.svg de 1.7 MB y PNGs de hasta 2.8 MB en rowivectors/ (existen ya los .webp de 44-60 KB sin usar) — servir los webp baja el LCP.

## 2 · Campaña de marketing — hero + landings corporativos para ads

El hero actual del sitio vivo ya está reencuadrado a relaciones: «*Entiende tus relaciones. Comunícate mejor.*» Es un buen punto de partida. La oportunidad ahora es no depender de un solo hero genérico, sino construir **landings por segmento** que alimenten campañas de ads con mensaje y CTA específicos por audiencia — y medir cada canal.

### 2.1 · Arquitectura de landings (una por intención de ad)

| Landing                 | Audiencia / ad                       | Promesa (headline)                                  | CTA                    |
|-------------------------|--------------------------------------|-----------------------------------------------------|------------------------|
| /p/conversacion-dificil | Individuo con un conflicto pendiente | «Di mejor lo difícil con quien te importa.»         | Preparar conversación  |
| /p/parejas-familia      | Parejas / familias                   | «Entiéndanse mejor, no solo discutan menos.»        | Ver nuestra afinidad   |
| /p/managers             | Líderes de equipo (B2B)              | «Menos fricción en tu equipo, sin vigilar a nadie.» | Solicitar piloto       |
| /p/coaches              | Coaches Six Seconds                  | «La capa de práctica diaria entre sesiones.»        | Invitar a mis clientes |
| /p/empresas             | HR / People (B2B)                    | «Comunicación medible, privacidad radical.»         | Hablar con ventas      |

### 2.2 · Requisitos técnicos para que los ads conviertan

- **Atribución arreglada (P1 real):** hoy la invitación relacional manda `?source=rel_invite` a `/register`, pero `/register` no lee `source` — se pierde. Sin esto, no sabrás qué ad/canal convierte. Es el fix de mayor ROI para ads.
- **Valor antes de registro:** los CTA deben llevar a `/pre-sei` (insight real sin login), no al demo de ECO actual, que es un mockup hardcoded (destinatario falso «Carlos Ruiz», botón «regenerar» que solo finge). Un demo falso en una campaña paga daña la confianza.
- **Reordenar registro:** el paso 0 hoy es elegir precio antes de ver el producto. Para tráfico de ads: valor → cuenta → plan.
- **SEO de apoyo:** añadir JSON-LD (Organization, SoftwareApplication) — único hueco SEO real; robots/sitemap/OG ya existen y funcionan.
- **Píxeles y UTM:** cada landing captura `utm_*` (ya soportado en `/register`) + el nuevo source; eventos de funnel ya instrumentados (`rel_invite_opened` / `accepted`).

*Nota de marca:* sin métricas ni testimonios inventados. Apóyate en Six Seconds (validación real) y en datos propios cuando existan. La credibilidad es el moat.

### 3 · Roadmap a 10/10 por categoría

Score actual (auditoría verificada) vs. meta, y la palanca concreta para cerrar la brecha. Las palancas son acciones reales sobre código que existe, no reescrituras.

| Categoría           | Hoy | Meta | Palanca para llegar a 10                                                   |
|---------------------|-----|------|----------------------------------------------------------------------------|
| Producto            | 8   | 10   | Validar el loop ECO→invitación→afinidad con la cohorte EQ Day.             |
| UX                  | 6   | 10   | Reordenar registro (valor primero); unificar los 2 flujos de invitación.   |
| Diseño              | 6   | 10   | Servir .webp existentes; favicon ligero; sistema visual de landings.       |
| Conversión          | 6   | 10   | Arreglar atribución source; CTA a /pre-sei; demo ECO real.                 |
| Retención           | 6   | 10   | Activar check-in post-conversación + memoria relacional (infra ya existe). |
| Monetización        | 5   | 10   | Pricing por profundidad relacional, no por features/tokens.                |
| Seguridad           | 7   | 10   | Rate limit en login/registro + captcha; quitar default secreto MFA.        |
| Performance         | 5   | 10   | Cerrado el peso de public/; comprimir assets; medir Lighthouse real.       |
| Escalabilidad       | 5   | 10   | Webhook fuera de rate limit; Redis (Upstash) para rate limit distribuido.  |
| Potencial unicornio | 8   | 10   | Grafo relacional consentido + canal Six Seconds + datos longitudinales.    |

## 4 · Acciones priorizadas (verificadas en código)

### P0 — antes de cualquier lanzamiento

| Acción                                                             | Estado                      | Esfuerzo |
|--------------------------------------------------------------------|-----------------------------|----------|
| Sacar datasets de public/ (fuga de datos)                          | ✓ HECHO esta sesión         | —        |
| Excluir /api/stripe/webhook del rate limit (10/min → 429 en pagos) | Pendiente · verificado real | Bajo     |
| Migrar seed a S3/R2 firmado (privacidad real del dataset)          | Pendiente                   | Medio    |

### P1 — semana 1

| Acción                                               | Estado                      | Esfuerzo |
|------------------------------------------------------|-----------------------------|----------|
| Rate limit + captcha en login y /api/auth/register   | Pendiente · verificado real | Medio    |
| Quitar default secreto MFA hardcodeado (fail-closed) | Pendiente · verificado real | Bajo     |
| Arreglar atribución source en /register (ads/funnel) | Pendiente · verificado real | Bajo     |
| Verificar guards internos de /api/admin/benchmarks/* | Pendiente · verificado real | Bajo     |
| Demo ECO real o redirigir CTA a /pre-sei             | Pendiente · verificado real | Medio    |
| Comprimir assets (webp, favicon)                     | Pendiente · verificado real | Bajo     |
| Añadir JSON-LD structured data                       | Pendiente · verificado real | Bajo     |

### P2 — mes 1

| Acción                                                          | Estado                      | Esfuerzo |
|-----------------------------------------------------------------|-----------------------------|----------|
| Reordenar wizard de registro (valor → cuenta → plan)            | Pendiente                   | Medio    |
| Unificar flujos de invitación (/invite legacy vs /r SIA)        | Pendiente                   | Medio    |
| Idempotencia atómica webhook↔ledger + unique en stripeInvoiceId | Pendiente · verificado real | Medio    |
| Redis (Upstash) para rate limit distribuido                     | Pendiente                   | Medio    |
| Pricing por profundidad relacional                              | Pendiente                   | Medio    |

Lo que la auditoría externa marcó pero NO hay que tocar (verificado falso o ya resuelto): home client-side, robots/sitemap ausentes, links /stories y /resources muertos, webhook «stuck en PROCESSING», CSRF sin Origin, CSP unsafe-eval en producción, payment\_failed pisando SUCCEEDED. Todos descartados contra el código.

## 5 · Pendientes clave — lista de seguimiento

Los seis pendientes acordados con el fundador, con su estado a esta fecha. El primero ya está implementado y probado en esta sesión; los otros cinco quedan abiertos con su esfuerzo y el lugar del código donde se intervienen.

| # | Pendiente                                                                                                                                                                  | Estado                      | Esf.  |
|---|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|-------|
| 1 | Excluir /api/stripe/webhook del rate limit (10/min → 429 en pagos).<br>RATE_LIMIT_EXEMPT_PATHS en middleware.ts; probado.                                                  | ✓ HECHO                     | —     |
| 2 | Migrar seed a S3/R2 privado con URLs firmadas (Blob v2 solo es público). Loader seedSource.ts abstraído; código listo, falta bucket+claves del fundador.                   | ■ LISTO<br>(falta clave)    | Medio |
| 3 | Arreglar atribución source en /register (se perdía ?source=rel_invite).<br>Email + OAuth; canal crudo en UserAcquisition.channel. OAuth ahora SÍ registra atribución.      | ✓ HECHO                     | Bajo  |
| 4 | Rate limit + captcha en login y /api/auth/register. authStrict cableado (5/5min) en ambos. Captcha Turnstile fail-safe listo; falta clave para activarlo.                  | ✓ HECHO<br>(captcha opt-in) | Medio |
| 5 | Demo ECO honesto + CTA a /pre-sei (valor real sin login). Badge «ejemplo ilustrativo» en 4 idiomas; CTA primario a /pre-sei con atribución.                                | ✓ HECHO                     | Medio |
| 6 | Pricing por profundidad relacional (espina narrativa SIA). Campo relationalDepth + helpers (Gratis→Relacional→SEI→Acompañado→Contexto) en 4 idiomas. Sin inventar precios. | ✓ HECHO                     | Medio |

**Estado a esta fecha:** 5 de 6 implementados y verificados (TS compila limpio, 986 tests pasan). El #2 y el captcha del #4 quedan «listos pero inactivos»: el código está completo y solo requieren credenciales del fundador (bucket S3/R2 firmado; clave TURNSTILE\_SECRET\_KEY). El captcha es fail-safe: omitido mientras no haya clave, sin romper el flujo. Para el #2, mientras no haya bucket privado los datasets viven en data/seed/ local (gitignored) — la fuga pública ya está cerrada.